



Assignment 2.1: Architecture Review Findings

Group 2: Brian Che, O.Kingsley Ero, Joshua Remington, Mikalou Nikiema, Mohammad Ahmed, and Shivam Patel

Shiley-Marcos School of Engineering (SMSE), University of San Diego

CYBR-516-01B: Cyber Engineering Research II

Professor Douglas Magedman

07/06/2026

		Client	Design World
		Doc #	DW0003
		Rev. #	Rev 1
Effective Date	07/06/26		

Table of Contents

1. Summary of the Current-State Architecture	3
Key Components:	3
2. Key Assumptions:	3
3. Security Gaps and Weaknesses	4
4. Governance & Enforcement Gaps	5
5. AI-Specific Risks	5
6. Technical and Operational Constraints	6
7. Approvals	6

	AI Systems & Security Requirements Report	Client	Design World
		Doc #	DW0003
		Rev. #	Rev 1
Effective Date	07/06/26		

1. Summary of the Current-State Architecture

The current-state architecture depicts an AI system embedded in the workflow and operations at Design World. This AI architecture shows a zero-trust model with clear boundaries indicating Identity and Edge Defense, Business/App Subnet, and Orchestration and Execution.

Key Components:

- **Identity and Edge Defense:** Users will access via an OpenVPN connection with SSO/MFA. Their connection passes through a Cloud WAF for session validation and payload inspection. Their destination is an Ubuntu Workstation found in the Business Subnet. Connection to the Orchestration layer goes through the Ubuntu Workstations' connection to internal applications and systems.
- **Orchestration Layer:** An Orchestration layer allows the fetching of data using a Service Account from a Windows File Server. This interacts with a Local Vector Database (RAG) and Ollama LLM (local) for inferences.
- **Inference and Execution:** The system queries a Tool-Calling Logic that generates responses, executes tools, and stores artifacts. The query results will be returned to the user.
- **Data Flows:** Blue connections are used for RAG aggregation; Green connections are used for actions; Solid Black connections are used for control flows; Dashed Black connections are used for status. The design allows local LLM execution, privileged execution on the CentOS host, and secure egress.

2. Key Assumptions:

- **Local and air-gapped elements reduce external exposure:** The Ollama LLM is marked as local, indicating that it runs entirely in the Orchestration/Inference layers. The Local Vector Database supports RAG without external calls.
 - o **Justification:** The diagram shows isolated components in the action layer and no direct internet egress from core AI components.

	AI Systems & Security Requirements Report	Client	Design World
		Doc #	DW0003
		Rev. #	Rev 1
Effective Date	07/06/26		

- **Zero-trust identity is enforced at the edge:** All users accessing the VPN require an OpenVPN setup and SSO/MFA, with the Cloud WAF inspecting payloads before reaching the business subnet.
 - o Justification: “Identity and Edge Defense” boundary clearly outlines auth steps and validation.
- **Service accounts and privileged execution are controlled but shared:** Tool execution uses the user’s Service Account Credentials and writes artifacts to the File Server.
 - o Justification: Visible credential flows to Windows File Server and tool paths.
- **RAG and tool-calling enable dynamic but contained actions:** Queries feed the LLM for tool-calling logic and final synthesis before response delivery.
 - o Justification: Tool-Calling Logic and Final Synthesis connections are used with the tools and show status feedback loops.

3. Security Gaps and Weaknesses

- **Single LLM without redundancy or monitoring:** The Ollama LLM is a central component but lacks visible output validation, fallback mechanisms, and logging. A compromised model could allow for malicious tool calls without proper stops.
- **Tool Privilege Access:** Tools may allow for execution and writing to File Server using service accounts; there is a lack of approval gates and sandboxing. Bypassing initial authentication or compromising a high-privilege account will allow for strong controls over the system.
- **Lateral movement risks:** The shared subnet can allow for direct movement without secondary authentication, allowing for easy lateral movement.
- **Lack of Data Flow controls:** Local Vector Database and file writing do not indicate security mechanisms are in place, such as encryption and access control.
- **Missing response controls:** There is no visible SIEM, audit logging for tools, or revocation of service accounts.

		Client	Design World
		Doc #	DW0003
		Rev. #	Rev 1
Effective Date	07/06/26		

4. Governance & Enforcement Gaps

- **No Execution or Approval Guardrails:** Data from the orchestrator is not checked or filtered before it is passed to the Ollama LLM. Unauthorized or malicious data can reach the Ollama LLM which can result in RAG or Model poisoning. A successful attack can lead to proprietary engineering files exfiltration.
- **No Centralized and secure logging:** there is no isolated or immutable directory for security information logs or audit logs. All logs must be retained and secured for incident response and for legal and regulatory compliance.
- **No Validation of Tools outputs:** The system assumes all tool-generated content is safe, creating a vulnerability where malicious tool outputs can compromise the LLM. Malicious output can expose proprietary engineering files and manipulate the system to execute unauthorized actions such as deleting files or sending phishing emails.

5. AI-Specific Risks

- **Indirect Prompt Injection Vulnerabilities:** An attacker could place a file containing malicious prompt on the file server which could be pulled by the RAG and executed by tool-calling logic. Some of the consequences of an indirect prompt injection are unauthorized access to privileged data, unauthorized data and system modifications, disruption of service, and data exfiltration.
- **RAG Data Poisoning:** The architecture lacks a process to filter poisoning attempts or unauthorized data. Successful RAG poisoning can lead to AI Hallucination, biased output, and data exfiltration.

6. Technical and Operational Constraints

- **Platform Restrictions:** The AI platform must be exclusively hosted on Linode, which can hinder growth and scalability, and the use of cloud-native managed guardrails and firewalls. Compared to other platforms such as AWS or Cloudflare, Linode is very limited for high-end AI hardware and built-in AI security features.

 SENTINEL CYBER CONSULTING	AI Systems & Security Requirements Report	Client	Design World
		Doc #	DW0003
		Rev. #	Rev 1
Effective Date	07/06/26		

- **Model restrictions:** The proprietary models cannot be fine-tuned to remediate vulnerabilities. Most remediation attempts must occur at the layers surrounding the Ollama LLM such as prompt guardrails, input filters, and output verification.

7. Approvals

Role	Printed Name	Signature	Date
Project Lead	Shivam Patel	<i>Shivam Patel</i>	06/29/26
Security Analyst	O.Kingsley Ero	<i>O.Kingsley Ero</i>	06/29/26
Security Analyst	Mohammad Ahmed	<i>Mohammad Ahmed</i>	06/29/26
Security Engineer	Joshua Remington	<i>Joshua Remington</i>	06/29/26
Security Engineer	Brian Che	<i>Brian Che</i>	06/29/26
Network Engineer	Mikailou Nikiema	<i>Mikailou Nikiema</i>	06/29/26
DW CEO			